Vercel the creator of Next.js suffers security breach



How the Attack Happened

In official security bulletins published on April 18 and April 19, 2026, Vercel confirmed a security incident. This incident didn't start with a flaw in Vercel's core system. The hackers found their way in through a third party AI tool called **Context.ai**, which a Vercel employee was using. By taking over the **Google Workspace** app connected to this tool, the attackers accessed the employee's account and then moved into specific internal Vercel areas.

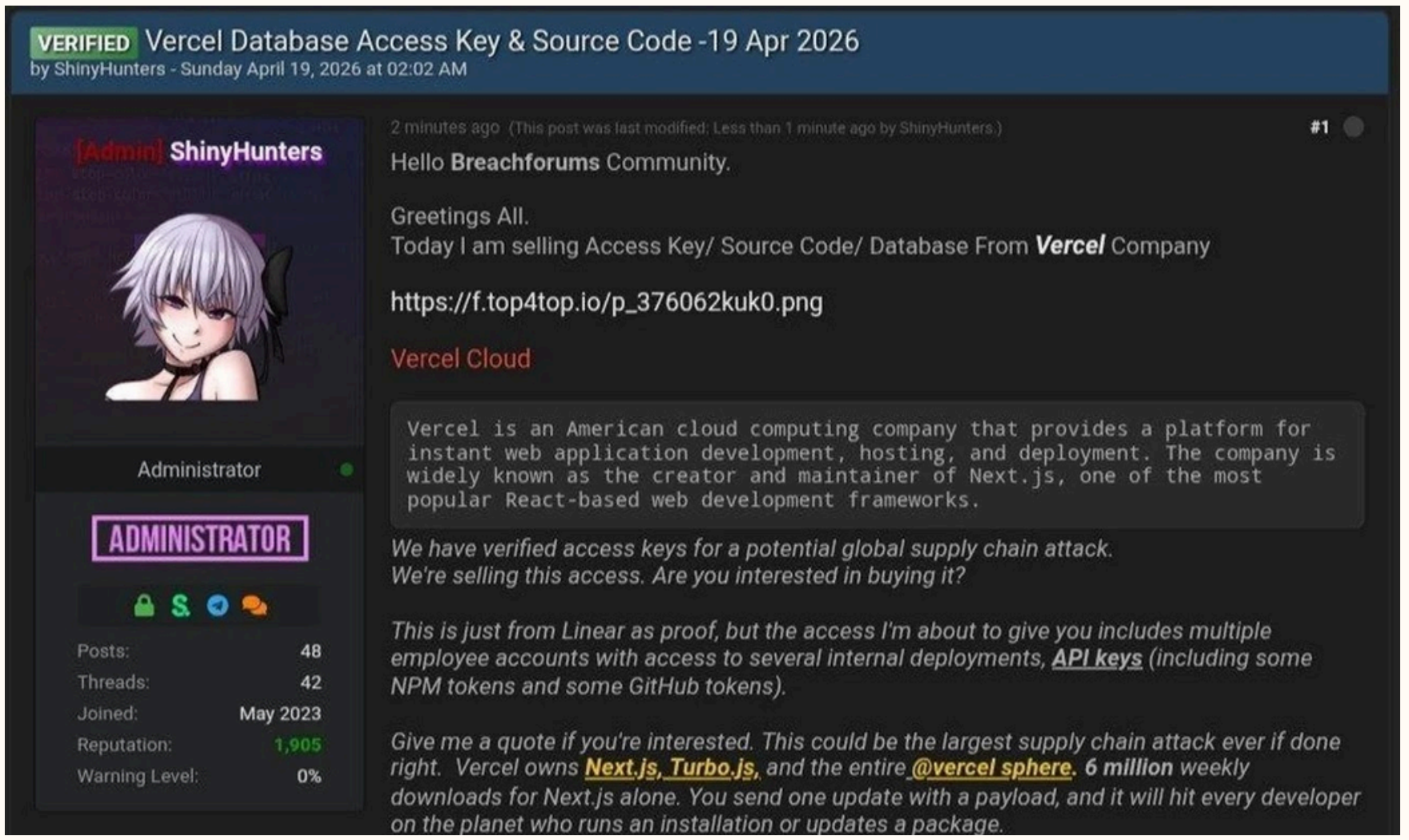
What Data Was Actually Leaked

Once inside, the attackers managed to read environment variables from a small number of customer setups.

- **The Safe Data:** Vercel confirmed that any variables clearly marked as sensitive were fully encrypted and stayed out of the attackers' hands.
- **The Exposed Data:** Any environment variables that were not marked as sensitive were exposed. This means any plaintext secrets left in these fields, such as API keys, database credentials, NPM tokens, and GitHub tokens, are now compromised. Fortunately, Vercel's main open source projects like Next.js and Turbopack remain completely safe.

The Truth Behind the Hacker's Identity

> The attacker posted the stolen data on BreachForums for a $2 million ransom, showing a text file of 580 Vercel employee records and screenshots of an internal dashboard to prove their claims. They claimed to be the famous **ShinyHunters** group. However, hackers actually connected to the real ShinyHunters told researchers they had nothing to do with this. This strongly points to a copycat trying to use a big name to get media attention and sell the data for more money.



Vercel's Quick Dashboard Updates

> To fix how the attackers were able to view this data, Vercel quickly updated its dashboard to give users better visibility and control. They added a new overview page for environment variables and improved the interface so developers can easily mark their secrets as sensitive, which ensures they are **encrypted**.

Extra Steps to Lock Down Systems

Beyond just changing passwords, Vercel asked users to take a few more technical steps to secure their environments:

- **Deployment Protection:** Users were told to make sure their protection settings are turned up to Standard or higher.
- **Bypass Token Rotation:** Anyone using Deployment Protection bypass tokens needed to replace them immediately.
- **IOC Auditing:** Vercel publicly identified the compromised OAuth app as an Indicator of Compromise **(IOC)** (110671459871-30f1spbu0hptbs60cb4vsmv79i7bbvqj.apps.googleusercontent.com), urging all Google Workspace administrators to audit their environments for its presence.